# Code Review Report - Run 2 update

Prepared by FusionHawk for Anarock Property Consultants Pvt. Ltd. | Date: 2026-10-16 | Weekly assessment, second run

**Summary:** Lint error, failing build, failing clean install and the register of missing items (no .env.example, no tests, no CI, no monitoring) are all unchanged and were re-confirmed by execution.

## Source state

Repository fusionhawk/Anarock main, HEAD 783060d at start of run. No application code has changed since commit b504988 (2026-10-08); only reports/docs were added after it. Verified by git diff d2929ad..HEAD -- anarock package.json (empty).

## Re-executed this run

npm ci (fails: lock out of sync, missing @emnapi/core and @emnapi/runtime); npm audit (13: 1 critical, 10 high, 2 moderate); next lint (1 error at list-your-property/page.js:993, 4 warnings); next build (fails on that lint error); Semgrep 1.181.0 with p/javascript, p/nextjs, p/owasp-top-ten, p/secrets (canary: 3 findings, project: 0 findings over 105 files); secret scan of working tree and full history (48 commits): 0 hits; 79 scripted API checks and 103 Playwright/axe checks against the local app started with no Zoho/Catalyst credentials.

## Live CRM (read-only)

getOrganization, getRecordCount only. Properties total 7,295 (previous report: 7,279). Push_to_Website=true: 393 (previous: 293). Leads with Lead_Source=Listing Platform: 7 (unchanged). Wherever the pages that follow say 293 of 7,279, the current figure is 393 of 7,295. Modules and field metadata were not re-queried this run.

## Test result variance

Run 2: API 43 pass / 36 fail (previous 45/34); browser 61 pass / 42 fail (previous 86/17). The sandbox network proxy blocked the app outbound calls (exchange-rates, location), producing console errors on every page, and axe-core was installed at a newer version (adds label-content-name-mismatch, no longer flags select-name). These are environmental, not regressions; the previous results remain the baseline. Logs: reports/evidence/08_api_tests_run2.log and 09_browser_tests_run2.log.

## Limitations

OWASP ZAP baseline scan NOT run (ZAP and Docker unavailable in the sandbox). GitHub secret scanning not re-run (previous run: Advanced Security not enabled on the repository). Scope document not re-fetched from Slack this run (repo copy unchanged). Slack project-tracker hours not re-compared. No credentials or CRM sandbox: Data Store, Stratus and CRM-write flows remain Blocked / Not verifiable.

The full report from the earlier run on this date follows this page. Evidence: reports/evidence/12_run2_delta.md.

# Code Review Report

Prepared by FusionHawk for Anarock Property Consultants Pvt. Ltd. | Date: 2026-10-16 | Repository: fusionhawk/Anarock, main (application code as of 21cf217; HEAD f2eabba, docs/reports only since)

## 1. Summary

The codebase is a working Next.js 14 front end with Zoho CRM lead integration, but it **currently fails to build** (lint error) and its lockfile is out of sync, listing pages are client-rendered (not the SEO-ready SSR the scope calls for), and a large share of the SoW (AI attributes, Search, SalesIQ, PageSense, analytics, view scoring) is not yet in the repository. Maintainability is held back by very large components, heavy commented-out code and no tests.

**Activities performed (raw logs in reports/evidence/):** (1) **GitHub pull** - git fetch/pull of fusionhawk/Anarock main, HEAD recorded (01_git_pull.log); (2) **Scope document** fetched from Slack (F0BP8478AE4) and compared with the repo copy - identical (11); (3) **Zoho CRM** inspected live, read-only, via the AnarockCRM connector: org, modules, Leads/Properties field metadata, record counts, COQL reads (10); (4) **Security checks**: npm audit (02); secret scan of all 131 tracked files and the full git history, 46 commits and 702,433 added lines (05); Semgrep SAST with 108 rules over 105 files, scanner proven on a known-bad canary file (06); GitHub secret-scanning attempted (07); manual review of all active API/lib code (about 5,000 lines, comments stripped); (5) **Build checks**: npm ci, next lint, next build (02-04); (6) **Request tests**: 79 scripted HTTP checks against the running app (08, script run_api_tests.sh); (7) **Browser tests**: 103 Playwright checks at 1366px and 375px including axe-core accessibility, link crawl and cookie checks (09, script run_browser_tests.js). The app ran locally with **no Zoho/Catalyst credentials**, so no request could reach production CRM.

**Limitations:** no credentials or CRM sandbox were available, so flows that need live Data Store, Stratus or CRM writes (listing results, detail data, lead creation end-to-end, duplicate-lead behaviour, KYC and market-stats data) could not be executed and are marked *Blocked*. SAST found no injection-class issues, but the main findings here are logic and design flaws that pattern-based tools do not detect. No load testing or external penetration test was done.

## 2. Findings

| ID | Area | Finding | How verified / evidence | Recommendation |
|---|---|---|---|---|
| C-01 | Build | Production build fails: ESLint error react/no-unescaped-entities at list-your-property/page.js:993. Four warnings (3 raw img tags, 1 hook dependency). The app cannot be deployed with the default build until fixed. | Executed: next lint and next build (Failed to compile) | Fix the apostrophe, address warnings, make lint a CI gate. |
| C-02 | Build | npm ci fails because package-lock.json is out of sync with package.json. | Executed: npm ci | Run npm install, commit lockfile, use npm ci in CI. |
| C-03 | Architecture | Three lead handlers (leads 883, lead2 445, lead3 1,130 active lines) are used by three distinct forms (Navbar callback, Home 'post a requirement', Shortlist enquiry). They are purposeful but copy-paste the Zoho auth, city lookup and duplicate logic, and validation has diverged (lead2 is the weakest). | Code: callers HomePage.js:1014, Navbar.js:519, WishlistClient.js:616 | Extract a shared Zoho client and validation module; keep one thin route per flow. |
| C-04 | Dead code | Large commented-out blocks: properties/route.js has 835 active lines out of 2,341; PropertiesClient.js has 2,047 comment lines of 5,031; CityPageClient.js 849 of 2,099; kyc/route.js 126. | Executed: line counts with comments stripped | Delete (git history keeps it). |

| ID | Area | Finding | How verified / evidence | Recommendation |
|---|---|---|---|---|
| C-05 | Maintainability | Very large client components: PropertiesClient 5,031 lines, HomePage 2,365, Navbar 1,596, list-your-property 1,502, PropertyDetailClient 1,163. No tests anywhere; no CI. | Executed: wc; find for test files = 0; Semgrep 0 findings (06) | Split by feature, add unit and Playwright tests and a CI pipeline. |
| C-06 | SEO / SoW 3.3 | Listing and detail pages are client-rendered shells. /properties serves only 'Loading properties...' in HTML; the detail page is a client component whose metadata is just a title from the URL slug. No description, Open Graph, canonical or JSON-LD (RealEstateListing/Offer) for listings, contrary to SoW. | Runtime: curl /properties; code properties/page.js and [id]/[name]/page.js | Server-render listing and detail from Data Store, add generateMetadata and JSON-LD, use ISR with on-demand revalidation. |
| C-07 | SEO | Sitemap is static with 4 URLs, two of which are invalid: /services&tools; and /list-property both return 404 (real routes are /services and /list-your-property). No property or city pages, default domain https://anarock.com. robots.txt disallows /wishlist but the route is /shortlist. Organisation JSON-LD points to /logo.png which does not exist in public/. | Runtime: curl sitemap.xml, robots.txt, HTTP 404 on both URLs; ls public/ | Generate the sitemap from Data Store, set NEXT_PUBLIC_BASE_URL, fix URLs and logo path. |
| C-08 | Correctness | Unknown property IDs return HTTP 200 (soft 404) with a page title from the slug. | Runtime: /properties/abc/xyz | Return notFound(). |
| C-09 | Features / SoW | 'AI search' is a no-op: the prompt is only logged. Only a minimum budget filter exists (code comment: maxBudget not used). All filtering and sorting is done in memory over the full cached table; Catalyst Search is not used. | Code: properties/route.js:372-377, 587-592 | Implement Catalyst Search and the AI-assisted search per SoW 5.2. |
| C-10 | Error handling | Malformed JSON returns 500 instead of 400 on /api/leads and /api/location; /api/micromarkets returns success:true with an empty list when its credentials are missing (masks failure); /api/location returns HTTP 200 on failure; message for phone 'abc' says 'Phone number is required'. | Runtime requests on each route | Return correct 4xx/5xx, surface failures, fix messages. |
| C-11 | Config / docs | catalyst.json uses a Windows path (D:\Catalyst\anarock); run-dev.bat committed; README referenced a functions/ folder that is not in the repo (fixed in this run); no .env.example; table ID hard-coded as default; empty file lib/propertyService.js; ~10 files with console.log noise. | Code read; git ls-files | Clean up configuration, add .env.example. |
| C-12 | Accessibility | axe-core (WCAG 2.1 A/AA) finds critical/serious violations: select-name (critical) on /properties and /list-your-property; aria-required-parent (critical, 2 nodes) and color-contrast (serious, 3) on home; color-contrast on /list-your-property (10 desktop / 5 mobile) and /kyc (2). /services has no h1. No horizontal overflow at 375px on 8 pages. | Executed: Playwright + axe-core on 8 pages at 1366px and 375px (09) | Label the selects, fix ARIA list structure and contrast; run axe in CI. |
| C-13 | CRM data contract | The code writes Lead_Source 'Listing Platform' and Sublead_Source 'Request a Callback' / 'Post a Requirement', but these are not in the CRM picklists (Lead_Source offers e.g. Website, OnlineStore; Sublead_Source offers 'Poster Requirement', 'Request a callback', 'Interested Properties'). CRM currently accepts them (7 leads with Lead_Source 'Listing Platform' exist) but reports and filters on the picklist will not group them. | CRM: Leads field metadata and COQL / record count | Add the values to the picklists and align case ('callback'). |

| ID | Area | Finding | How verified / evidence | Recommendation |
|---|---|---|---|---|
| C-14 | CRM readiness vs SoW | CRM Properties already has Push_to_Website (293 of 7,279 true), Has_Images and AI_Attributes_from_Images. The Interested_Properties subform used by lead3 exists. No property view-count / view-score field exists on Properties; the sync, Gemini, Stratus-push and revalidation Functions are not in the repo. | CRM: Properties field metadata, record counts; repo file list | Create the view-score field and build the Catalyst Functions. |
| C-15 | SEO (critical) | Every page declares its canonical URL as the homepage: layout.js sets alternates.canonical '/' globally, so /properties, property detail, KYC city and other pages all tell search engines they are duplicates of the home page. The property detail page also inherits the home meta description and has no listing JSON-LD. | Executed: 5 pages fetched, each returned canonical=https://anarock.com (08); code layout.js:52-53 | Set per-page canonical via generateMetadata; add per-property description and JSON-LD. |
| C-16 | Content / SoW 5.1 | Footer links to /aboutus, /privacy-policy, /terms-of-use and /rera all return 404. The scope lists About, Contact, Privacy Policy and Terms pages in the MVP. | Executed: link crawl from home (09) | Create the pages or remove the links; privacy and terms are needed before go-live (cookie consent and lead capture). |
| C-18 | Features / compliance | Property detail page has no inquiry form (the contact-modal state setter is declared but never used), although SoW 5.1 lists one. The cookie-consent banner is mounted only in HomePage.js, so visitors landing directly on /properties or a detail page never see it. | Code: PropertyDetailClient.js:189; grep CookieConsent usage | Add the inquiry form to the detail page; mount consent in the root layout. |
| C-17 | Positives | Clear App Router layout; defensive validation and honeypot in /api/leads; token-refresh de-duplication and retry on 401; cache headers on read APIs; good use of timeouts on most external calls; consistent UI kit; responsive (no overflow at 375px). | Code read; Playwright | Keep. |

## 3. Scope coverage (Anarock CLA Online Listing Platform Scope)

| SoW item | Status | Evidence |
|---|---|---|
| SSR/SSG listing and detail pages for SEO | Not met | Client-rendered shells (C-06) |
| Per-page metadata, JSON-LD, OG/Twitter | Partial | Home only; none on listing/detail |
| Dynamic sitemap.xml, robots.txt | Partial | Static sitemap with invalid URLs (C-07) |
| Faceted filters (city, type, micromarket, min budget, area, seats) | Partial | Present; no max budget; in-memory |
| Full-text / AI-assisted search, Catalyst Search | Not met | Prompt only logged (C-09) |
| Related-property recommendations | Partial | Fetch present in detail client; not testable without data |
| Lead capture to CRM | Present | 3 flows (C-03) |
| Currency switch INR/AED/USD/EUR/SGD | Present | /api/exchange-rates returns 5 currencies (tested) |
| Units switch (SoW: feet, metre, sq ft, sq m) | Partial | Area switch sq ft / sq m is implemented (Navbar, preferences.js, cards, detail, compare, shortlist, market stats); linear feet/metre (e.g. distance to metro/airport) is not converted |
| Image galleries from Stratus | Partial | Stratus bucket helper and next/image host configured; not testable |
| CRM to Stratus sync, Gemini attributes, Data Store publish, revalidation | Not in repo | CRM fields exist (C-14) |
| Zoho SalesIQ, PageSense, GA4/GTM, cookie consent | Cookie consent only | No SalesIQ/PageSense/GA code found |
| Property view tracking to CRM view score | Not found | No code, no CRM field |
| Compare, wishlist/shortlist | Present (client-side) | localStorage; wishlist API is a stub |